

Glossary

Term	Definition
OWASP Top 10	A regularly updated list of major security risks in web applications.
Broken Access Control	When a user can access information or actions they are not authorized to access.
SAST	Security testing performed by analyzing source code without executing the application.
DAST	Security testing performed against a running application.
IAST	Security testing that combines aspects of static and dynamic analysis while the application runs.
SCA	Analysis of third-party libraries and dependencies for known vulnerabilities.
Threat Modeling	Identifying possible threats, vulnerabilities, and attack methods before or during development.

Technical Learning Report: Day 1

Date: October 7, 2026

Intern Name: Shekhar Singh Rawal

Subject: Introduction to Security Testing & OWASP Top 10

1. Objective

The objective of Week 6 Day 1 was to build an understanding of **security testing as a non-functional testing type** and study the major security risks identified by the OWASP Top 10. The learning focused on understanding common vulnerabilities, security-testing objectives, different security-testing techniques, and the security-testing lifecycle. The main focus was on understanding security risks from a **business-impact perspective**, especially risks involving sensitive information, unauthorized access, and application security.

2. Security Testing

Definition

Security Testing is a type of non-functional testing that verifies whether an application, system, or network is protected against security threats, vulnerabilities, and unauthorized access.

The main purpose is to identify security weaknesses before attackers can exploit them.

Main Security Concerns

Security testing focuses on areas such as:

- Unauthorized access
- Sensitive-data protection
- Authentication
- Authorization
- Application vulnerabilities
- Security configuration
- Attack resistance

3. OWASP Top 10

OWASP (Open Worldwide Application Security Project) Top 10 is a regularly updated report that highlights major security risks for web applications.

The handwritten notes covered the following ten vulnerabilities:

1. Broken Access Control
2. Cryptographic Failures
3. Injection
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable and Outdated Components
7. Identification and Authentication Failures
8. Software and Data Integrity Failures
9. Security Logging and Monitoring Failures
10. Server-Side Request Forgery (SSRF)

4. OWASP Top 10 – Detailed Notes

4.1 Broken Access Control

Definition

Broken Access Control occurs when a user can access information or perform actions that they are not authorized to access.

Example

A normal user changes:

/user/123

to:

/user/124

and is able to view another user's account.

Business Impact

This can expose private user information and allow unauthorized actions.

4.2 Cryptographic Failures

Definition

Cryptographic Failures occur when sensitive information is not properly protected using encryption or other appropriate security mechanisms.

Example

A website stores passwords in plain text. If attackers gain access to the database, they can directly obtain the passwords.

Business Impact

This can expose passwords, personal information, payment information, or other sensitive data.

4.3 Injection

Definition

Injection occurs when an attacker sends malicious input that is interpreted as code or a command by the application.

Example

An attacker enters SQL code into a login form in an attempt to bypass authentication.

Business Impact

Injection attacks can lead to unauthorized access, data exposure, or manipulation of application data.

4.4 Insecure Design

Definition

Insecure Design occurs when security weaknesses are built into the application's design or business logic.

Example

A password-reset system uses an easily guessable security question such as:

"What is your country?"

Business Impact

An attacker may exploit weak business logic even when the application has been technically implemented correctly.

4.5 Security Misconfiguration

Definition

Security Misconfiguration occurs when security settings are incorrectly configured or unsafe default settings are left enabled.

Example

A website displays detailed error messages that reveal database information.

Business Impact

Attackers may obtain information that helps them understand or attack the system.

4.6 Vulnerable and Outdated Components

Definition

This vulnerability occurs when an application uses outdated software, libraries, frameworks, or dependencies containing known security vulnerabilities.

Example

A website uses an outdated framework version with a publicly known security vulnerability.

Business Impact

Attackers may exploit the known vulnerability to compromise the application.

4.7 Identification and Authentication Failures

Definition

These failures occur when authentication or user-identification mechanisms are weak or incorrectly implemented.

Example

A website allows unlimited login attempts, allowing an attacker to repeatedly try stolen passwords.

Business Impact

Weak authentication can lead to unauthorized access to user accounts.

4.8 Software and Data Integrity Failures

Definition

This occurs when an application does not properly verify the integrity or trusted source of software, updates, dependencies, or data.

Example

An application installs an update from an untrusted source containing malicious software.

Business Impact

Malicious software or modified data can compromise the application and its users.

4.9 Security Logging and Monitoring Failures

Definition

This occurs when security events are not properly recorded, monitored, detected, or reported.

Example

An attacker performs thousands of failed login attempts, but the system does not alert administrators.

Business Impact

Security attacks may continue for a long time without being detected.

4.10 Server-Side Request Forgery (SSRF)

Definition

SSRF occurs when an attacker tricks a server into making requests to resources that the attacker should not directly access.

Example

An attacker manipulates a URL so that the web server accesses an internal administrative page that is not publicly accessible.

Business Impact

SSRF can expose internal resources and services that should remain protected.

5. Security Testing Techniques

The handwritten notes covered several security-testing techniques.

5.1 SAST – Static Application Security Testing

SAST analyzes source code without executing the application.

Source Code

↓

SAST

↓

Security Weaknesses

It can help identify problems such as potential SQL injection or buffer-overflow risks during development.

5.2 DAST – Dynamic Application Security Testing

DAST tests a **running application** to identify security weaknesses.

Running Application



DAST



Potential Vulnerabilities

It allows testers to evaluate the application's security from an external perspective.

5.3 IAST – Interactive Application Security Testing

IAST combines aspects of static and dynamic testing and provides security feedback while the application is running.

It can provide more context about vulnerabilities discovered during application execution.

5.4 SCA – Software Composition Analysis

SCA checks third-party libraries and dependencies for:

- Known vulnerabilities
- Outdated components
- Dependency risks
- License issues

It is particularly useful for modern applications that depend heavily on external libraries.

5.5 Manual Penetration Testing

Manual penetration testing uses human security expertise to simulate sophisticated attacks.

The handwritten notes identified examples such as:

- Business-logic attacks
- Chaining vulnerabilities
- Social-engineering vectors

Manual testing can identify complex issues that automated tools may not detect.

6. Security Testing Objectives

The handwritten notes identified the following major objectives:

1. Find Security Weaknesses

Identify vulnerabilities before attackers can exploit them.

2. Test Resistance Against Attacks

Determine whether the application can withstand unauthorized access and other attacks.

3. Ensure Compliance

Verify that the application follows applicable security standards and requirements.

4. Protect Sensitive Data

Ensure confidential information is properly protected.

5. Reduce Security Risk

Identify and reduce security risks before deployment.

These objectives connect security testing directly with business risk and application protection.

7. Security Testing Lifecycle

The handwritten notes described **nine phases of security testing**.

1. Planning

Define the security-testing scope, objectives, and testing requirements.

Define Scope → Define Objectives → Plan Testing

2. Reconnaissance

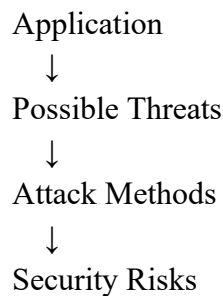
Collect information about the system being tested.

The purpose is to understand the target system and its available components.

3. Threat Modeling

Identify possible threats and attack methods.

For example:



4. Vulnerability Scanning

Identify potential security weaknesses using security-testing tools or scanning techniques.

5. Exploitation

Safely test whether identified vulnerabilities can actually be exploited.

The objective is to verify the real impact of a vulnerability.

6. Risk Assessment

Determine the security risk and potential impact of identified vulnerabilities.

A vulnerability affecting payment information would normally receive much greater business attention than a minor cosmetic issue.

7. Reporting

Document the identified security problems and provide recommendations for resolving them.

A security report should clearly communicate:

- Vulnerability
- Impact
- Evidence
- Risk
- Recommended solution

8. Remediation

Fix the identified security issues.

Developers or responsible teams implement the required security improvements.

9. Retesting

Test the application again after remediation to confirm whether the security issue has been properly resolved.

Find Issue



Fix Issue



Retest



Issue Resolved?

8. Security Testing and Business Risk

Security testing should be prioritized according to **business impact**.

For example:

Security Area	Business Risk	Priority
Payment information exposure	Very High	Critical
Unauthorized account access	Very High	Critical
Password exposure	Very High	Critical
Personal user information	High	High
Security configuration	High	High
Minor information disclosure	Medium	Medium
Cosmetic security-related issue	Low	Low

The key principle is:

The greater the potential business impact, the higher the security-testing priority.

9. Connection Between Security Testing Techniques and Lifecycle

The different techniques can be used at different points of the security-testing process.

Technique	Main Focus
SAST	Source-code security
DAST	Running application security
IAST	Security during application execution
SCA	Third-party dependencies
Manual Penetration Testing	Human-driven attack simulation

These techniques complement each other rather than replacing one another.

10. Key Findings & Best Practices

1. Security testing is an important **non-functional testing type**.
2. OWASP Top 10 helps QA engineers understand common web-application security risks.
3. **Broken Access Control, Cryptographic Failures, and Injection** can have serious business impact.
4. Security weaknesses can exist in application design, configuration, dependencies, authentication, and monitoring.

5. **SAST, DAST, IAST, SCA, and manual penetration testing** provide different security-testing approaches.
6. Security testing should begin with proper planning and continue through **retesting after remediation**.
7. Security vulnerabilities should be prioritized according to **business impact and risk**.
8. Logging and monitoring are important because attacks that are not detected can continue for a longer period.
9. Security testing is not only about finding vulnerabilities; it also involves **risk assessment, reporting, remediation, and retesting**.

11. Conclusion

Week 6 Day 1 introduced **Security Testing and the OWASP Top 10**. The handwritten study covered all ten major OWASP risks, including Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, outdated components, authentication failures, integrity failures, logging/monitoring failures, and SSRF.

The day also covered major security-testing techniques including **SAST, DAST, IAST, SCA, and Manual Penetration Testing**, followed by the security-testing objectives and nine-phase lifecycle from planning through retesting. The main learning was that security testing should be **risk-based and prioritized according to business impact**, particularly when sensitive data, authentication, payment information, or unauthorized access are involved.